

Conformità Legale e Adempimenti

App e attività di stampa fotografica

Silvestre Fotoservizi — Frattamaggiore (NA)

Versione del 18/05/2026

⚠ DISCLAIMER. Questo documento è una checklist informativa redatta a supporto tecnico. **NON** è consulenza legale né fiscale. Prima del rilascio in produzione è **OBBLIGATORIO** far validare contenuti e procedure da un avvocato e da un commercialista. La normativa cambia: rivedi la lista almeno ogni 12 mesi.

1. Privacy e GDPR (Regolamento UE 2016/679)

Tratti dati personali (email, telefono, foto dei clienti). Sei Titolare del Trattamento. La normativa di riferimento è il GDPR + il D.Lgs. 196/2003 come modificato dal D.Lgs. 101/2018.

1.1 Informativa privacy

- Pubblicata in app, sito e visibile in negozio.
- Contiene: titolare e contatti, DPO se presente, finalità, base giuridica, categorie di dati, periodo di conservazione, destinatari (Firebase, Stripe, ecc.), trasferimento extra-UE se presente, diritti dell'interessato, reclamo al Garante.
- Linguaggio chiaro e accessibile (art. 12 GDPR).
- Versionata: ogni modifica sostanziale deve essere comunicata e richiede nuovo consenso.

1.2 Consensi (devono essere granulari)

- Termini di Servizio + Privacy Policy: obbligatorio per usare il servizio.
- Marketing email/SMS: separato, OPT-IN esplicito, NON pre-checkato (vietato dal Garante).
- Profilazione: separato, opzionale.
- Foto utenti per portfolio del negozio: separato, opzionale.
- Per minori di 14 anni serve consenso del genitore (art. 2-quinquies D.Lgs. 196/2003).

1.3 Diritti degli utenti (artt. 15-22 GDPR)

- Accesso ai propri dati: l'utente può richiedere copia dei suoi dati.
- Portabilità: export in formato strutturato (es. JSON).
- Rettifica: modifica dati errati.
- Cancellazione (diritto all'oblio): elimina account e dati.
- Limitazione e opposizione al trattamento.
- Reclamo al Garante Privacy.

Implementazione tecnica nell'app: pulsanti 'Esporta i miei dati' e 'Elimina account' nella schermata Account. Risposta entro 30 giorni.

1.4 Registro dei trattamenti (art. 30 GDPR)

Obbligatorio anche per piccole imprese se trattano dati su base regolare. Documento interno (non si pubblica). Deve elencare: finalità, categorie di interessati e dati, destinatari, trasferimenti, periodo di conservazione, misure di sicurezza.

1.5 DPA (Data Processing Agreement)

Devi avere un DPA firmato con ogni fornitore che tratta dati per te:

- Firebase / Google Cloud → DPA accettabile online dalla console.
- Stripe / payment provider → DPA disponibile nei loro Terms.
- Servizio email transazionale (SendGrid, Mailgun, ecc.) → DPA dedicato.
- Hosting / CDN → DPA del provider.

- Eventuale agenzia marketing → contratto + nomina a Responsabile.

1.6 DPO (Data Protection Officer)

NON obbligatorio per attività commerciale di piccole dimensioni che NON tratta categorie particolari di dati su larga scala. Le foto in sé non sono categoria particolare (art. 9), MA se identificano persone (specie minori) vanno trattate con attenzione. Verificare con avvocato.

1.7 Data Breach

- Notifica al Garante entro 72 ore dalla scoperta (modulo online sul sito del Garante).
- Notifica agli utenti se il rischio è elevato.
- Tenere un registro interno delle violazioni (anche minori).
- Predisporre un piano di risposta scritto: chi fa cosa quando.

1.8 Trasferimento extra-UE

Firebase salva dati anche in USA. Dopo Schrems II è richiesto il DPF (Data Privacy Framework) e/o SCC (Standard Contractual Clauses). Firebase ha entrambi attivi. Va menzionato nell'informativa.

2. Adempimenti fiscali e contabili

2.1 Corrispettivi telematici

Dal 2021 l'invio dei corrispettivi al SDI è obbligatorio per tutti gli esercizi commerciali. Il POS/registratore telematico in negozio già lo fa automaticamente per gli incassi 'paga in negozio'.

- Verifica con il commercialista che il misuratore fiscale sia abilitato 'corrispettivi telematici'.
- Se l'app gestisce vendite con pagamento online → corrispettivo elettronico via API (servizi: Fatture in Cloud, Aruba, TeamSystem) oppure documento commerciale equivalente.
- Tutti i corrispettivi devono essere trasmessi entro 12 giorni.

2.2 Fatturazione elettronica

Se il cliente chiede fattura (es. azienda, partita IVA), serve fatturazione elettronica via SDI. Integra l'app con un servizio di fatturazione:

Servizio	Prezzo annuo	Note
Fatture in Cloud	~70-180€	Italiano, ottimo per piccole imprese
Aruba Fatturazione	~25-50€	Economico, integrato con PEC
TeamSystem Digital Invoice	Variabile	Soluzione enterprise
FattureInCloud API	Da 96€	API per integrazione con app

2.3 IVA

- Stampa fotografica: aliquota ordinaria 22%.
- Servizi B2C: IVA inclusa nel prezzo esposto (art. 14 Codice del Consumo).
- Liquidazione IVA trimestrale o mensile in base al regime.
- Conservazione documenti fiscali: 10 anni (art. 2220 c.c.).

2.4 Conservazione digitale a norma

Fatture elettroniche e corrispettivi devono essere conservati con processo di conservazione a norma (firma digitale + marca temporale). Tutti i servizi sopra elencati lo includono. Costo aggiuntivo: 0 - 50€/anno.

3. Pagamenti elettronici e PCI-DSS

I dati delle carte di pagamento (numero, CVV, scadenza) sono regolati dallo standard PCI-DSS (Payment Card Industry Data Security Standard). Trattarli direttamente richiede certificazione PCI-DSS Livello 1 (~30.000€/anno) e infrastruttura dedicata: impraticabile per un piccolo esercizio.

⚠ NON memorizzare MAI numeri di carta, CVV o scadenze sui tuoi server. Una sola violazione = multe da centinaia di migliaia di euro + responsabilità penale.

3.1 Soluzione: usa un provider PCI-DSS Level 1

Il cliente inserisce la carta in un form fornito dal provider; i dati vanno direttamente ai server del provider (criptati). Tu ricevi solo un 'token'. L'esperienza per il cliente è identica: vede 'Paga con carta', inserisce qualsiasi Visa/Mastercard/Amex, senza creare account.

Provider	Commissione UE	Pro	Contro
Stripe	1.4% + 0.25€	SDK Flutter eccellente, standard mondiale	Lock-in tecnico
Mollie	1.8% (carte)	Trasparente, europeo, supporto IT	Meno SDK
Nexi XPay	Da concordare	Italiano, integrato banche IT	Onboarding più lento
Satispay Business	1% fissa	Popolare in Italia, no carte	Solo utenti Satispay
PayPal Commerce	2.9% + 0.35€	Trust elevato, copertura globale	Commissione alta

3.2 Antiriciclaggio

Per piccole transazioni di photo printing l'AML non si applica direttamente, MA: limite contanti per transazione = 5.000€ (2024+, variabile). Per pagamenti in negozio sopra soglia serve identificazione del cliente.

4. Diritti dei consumatori (Codice del Consumo D.Lgs. 206/2005)

4.1 Informazioni precontrattuali (art. 49)

Prima del 'compra ora' il cliente deve vedere chiaramente:

- Identità e contatti del venditore (Silvestre Fotoservizi + indirizzo + P.IVA).
- Caratteristiche principali del prodotto.
- Prezzo totale comprensivo di tasse.
- Modalità di pagamento, consegna, esecuzione.
- Diritto di recesso e relative modalità (o esclusioni).
- Garanzia legale di conformità (24 mesi).
- Codice di condotta se applicabile.

4.2 Diritto di recesso

⚠ IMPORTANTE: i prodotti personalizzati (fotolibri, stampe foto, tele personalizzate, magneti con foto, gadget personalizzati) sono ESCLUSI dal diritto di recesso (art. 59 lett. c, Codice del Consumo). Va indicato chiaramente prima dell'ordine.

Per prodotti non personalizzati (improbabile in questo business) si applica il recesso di 14 giorni.

4.3 Garanzia legale

- Garanzia di conformità 24 mesi anche su prodotti personalizzati (difetti di stampa, materiali).
- Il cliente ha diritto a riparazione o sostituzione gratuita.
- Tenere registro reclami.

4.4 Risoluzione controversie

Indica l'esistenza della piattaforma ODR (Online Dispute Resolution) della Commissione UE:
<https://ec.europa.eu/consumers/odr> — link da mostrare in Termini e fattura.

5. Tutela dei minori

5.1 Età minima per registrarsi

In Italia l'età minima per il consenso autonomo al trattamento dati è 14 anni (art. 2-quinquies D.Lgs. 196/2003). Sotto i 14 anni serve consenso del genitore. Implementazione: chiedere data di nascita in registrazione + se <14, flusso di consenso genitoriale (link via email al genitore).

5.2 Foto di minori

- Le foto di minori richiedono particolare cautela: liberatoria firmata da entrambi i genitori.
- Mai usare foto di minori per marketing senza liberatoria specifica.
- Cancellazione foto su richiesta = priorità assoluta.
- Se l'app rileva contenuti potenzialmente illegali (CSAM): obbligo segnalazione alle autorità.

6. Foto degli utenti — gestione e responsabilità

- Le foto sono dati personali (art. 4 GDPR) anche se non contengono volti.
- Conservazione: solo per il tempo necessario all'esecuzione dell'ordine + grace period.
- Proposta: cancellazione automatica 30 giorni dopo il ritiro (configurabile).
- Storage criptato a riposo + HTTPS in transito (Firebase Storage di default).
- Backup criptati, accessi loggati.
- Mai usare le foto degli utenti per altri scopi (training AI, portfolio) senza consenso esplicito separato.
- Se il cliente porta foto contenenti persone terze, è responsabilità del cliente avere il consenso di quelle persone. Indicarlo nei Termini.

6.1 Contenuti vietati

I Termini devono vietare esplicitamente:

- Materiale pedopornografico (CSAM) — obbligo segnalazione alle autorità.
- Contenuti che violano diritti d'autore di terzi.
- Materiale che incita all'odio o alla violenza.
- Documenti d'identità di terzi senza autorizzazione.

7. App Store Apple e Google Play

7.1 Requisiti obbligatori per la pubblicazione

- Account sviluppatore Apple (99€/anno) e Google Play (25€ una tantum).
- URL pubblica di Privacy Policy (deve essere raggiungibile, non solo dentro l'app).
- URL di supporto (email o pagina di contatto).
- Privacy Nutrition Labels (Apple) o Data Safety section (Google): dichiarare TUTTI i dati raccolti, finalità, condivisione con terzi.
- Schermate dell'app, descrizione, icona di alta qualità.
- Classificazione per età (in genere 4+).

7.2 Linee guida che riguardano la nostra app

- Apple: vietato linkare a pagamenti web esterni per beni digitali (qui vendiamo beni fisici, OK).
- Apple: se l'app permette upload di contenuti utente, serve sistema di segnalazione abusi + blocco utenti molesti.
- Google: stessa cosa più verifica della destination URL del dominio.
- Entrambi: aggiornamento delle Privacy Labels ad ogni modifica di trattamento dati.

7.3 In-App Purchase vs pagamento esterno

I beni FISICI (stampe, fotolibri, tele) possono essere pagati con metodi esterni (Stripe, Satispay) — non è obbligatorio IAP Apple/Google. Solo per beni digitali (es. crediti virtuali, abbonamenti pro) Apple impone IAP (30% commissione).

8. Marchio e proprietà intellettuale

8.1 Marchio 'Silvestre Fotoservizi'

- Verificare la registrazione del marchio presso UIBM (Ufficio Italiano Brevetti e Marchi) o consultare l'archivio TMview UE.
- Se non registrato, valutare la registrazione (~200-400€) per protezione su classe 40 (servizi fotografici) e classe 41 (servizi di stampa).
- L'icona dell'app e il logo sono opere protette da diritto d'autore automaticamente.

8.2 Software dell'app

- Il codice scritto è di proprietà del committente (te), salvo diverse pattuizioni.
- Tenere documentazione dei termini di sviluppo (questo include la cronologia delle conversazioni).
- Le librerie open-source utilizzate (Flutter, Firebase SDK, ecc.) hanno le loro licenze: l'app deve esporre la lista nella sezione 'Crediti' / 'Open Source'.

8.3 Immagini di stock

Il catalogo usa immagini da Pexels (Pexels License) — 36 immagini scaricate via API Pexels e cachate in Firestore (collection 'catalog_images'). Pexels License consente uso commerciale gratuito; l'attribuzione non è obbligatoria ma 'gradita'. L'app mostra comunque l'attribuzione 'Photo by [Autore] - Pexels' come chip cliccabile su ogni scheda prodotto e categoria, per buona pratica e trasparenza.

Quando avrai tue foto reali dei prodotti, basta sostituirle nello stesso campo 'url' dei documenti 'catalog_images' su Firestore (o caricarle su Cloudinary e mettere l'URL Cloudinary). Le attribuzioni Pexels verranno automaticamente nascoste se il campo 'photographer' è vuoto.

⚠ Conserva sempre traccia della fonte di ogni immagine. Se sostituisci con foto tue, assicurati di avere liberatorie dai soggetti riconoscibili (modelle, bambini, persone identificabili in primo piano) — vedi sezione 4 GDPR diritti di immagine.

9. Coperture assicurative consigliate

Polizza	Cosa copre	Prezzo indicativo annuo
RC Professionale	Danni a clienti da errori (stampe rovinare, perdita foto)	150-400€
Cyber Risk	Data breach, attacchi informatici, ricatti ransomware	300-800€
Tutela legale	Spese legali per controversie con clienti	100-250€

Contattare broker assicurativo specializzato in PMI digitali. Alcune compagnie italiane: Generali, UnipolSai, Reale Mutua, AXA, ITAS. Comparatori: Facile.it, ComparaSemplice.

10. Checklist pre-rilascio (da completare prima dello store)

Documenti legali

- ☐ Privacy Policy redatta e validata (Iubenda o avvocato).
- ☐ Termini di Servizio redatti e validati.
- ☐ Cookie Policy (per il sito web/PWA).
- ☐ Informativa privacy in italiano + inglese (se rilasci anche in UE).
- ☐ Registro dei trattamenti compilato.
- ☐ DPA firmati con tutti i fornitori (Firebase, payment provider, email).

Adempimenti tecnici

- ☐ Consensi granulari implementati in registrazione (TOS+Privacy obbligatori, marketing opzionale).
- ☐ Funzione 'Esporta i miei dati' attiva.
- ☐ Funzione 'Elimina account' attiva.
- ☐ Cancellazione automatica foto dopo grace period.
- ☐ Storage criptato + HTTPS ovunque.
- ☐ Backup automatici + test ripristino.
- ☐ Log accessi e azioni sensibili.
- ☐ Sistema di segnalazione abusi (per upload utenti).
- ☐ Sistema di moderazione contenuti (anche solo automatico tipo Cloud Vision).

Fiscale

- ☐ Misuratore fiscale in negozio abilitato corrispettivi telematici.
- ☐ Servizio fatturazione elettronica configurato (Fatture in Cloud o equivalente).
- ☐ Liquidazione IVA programmata con commercialista.

- ☐ Numerazione documenti commerciali coerente.

Pagamenti (se attivi pagamento online)

- ☐ Account Stripe / Satispay attivato + KYC completato.
- ☐ Integrazione SDK testata in sandbox.
- ☐ Webhook attivo per conferma pagamento.
- ☐ Gestione rimborsi nel pannello admin.
- ☐ Riconciliazione contabile pagamenti online / corrispettivi mensile.

App Stores

- ☐ Account Apple Developer 99€ pagato.
- ☐ Account Google Play 25€ pagato.
- ☐ URL pubblico Privacy Policy attivo.
- ☐ URL pubblico supporto attivo.
- ☐ Privacy Labels Apple compilate accuratamente.
- ☐ Data Safety Google compilato accuratamente.
- ☐ Test interno + chiusi prima del rilascio pubblico.

Operativi

- ☐ Email aziendale dedicata privacy@silvestrefotoservizi.it.
- ☐ Procedura risposta richieste utenti (accesso, cancellazione) — entro 30 giorni.
- ☐ Piano risposta data breach scritto.
- ☐ Formazione staff (anche minima) su gestione dati.
- ☐ Assicurazione RC + Cyber attivata.

11. Costi indicativi anno 1 (stime di mercato)

Voce	Costo annuo	Note
Iubenda Plus (Privacy/Cookie/Termini)	~80€	Generatore conforme + aggiornamenti
Fatturazione elettronica (Aruba o Fatture in Cloud)	30-180€	In base al volume
Apple Developer	99€	Solo se rilasci su iOS
Google Play Developer	25€ una tantum	Solo Android
Firebase (Spark plan gratis, Blaze a consumo)	0-200€	Pochi clienti = quasi gratis
Dominio + email (silvestrefotoservizi.it)	20-50€	Se non hai già
Hosting Privacy Policy (Iubenda lo include)	0€	
Assicurazione RC + Cyber base	400-800€	Consigliato
Consulenza commercialista (extra)	200-500€	Setup iniziale corrispettivi/IVA
Consulenza legale (validazione una tantum)	300-1200€	Validazione policy + GDPR audit
Stripe / Satispay	Solo commissioni	Nessun fisso, %% per transazione
Stock photos premium (Adobe Stock)	30€/mese	Solo se non usi tue foto

Totale ragionevole anno 1: 1.500 - 3.500€ (escluse commissioni transazioni). Anno 2 in poi: -50% (consulenze una tantum eliminate).

12. Fornitori e servizi raccomandati

Categoria	Fornitore	Sito
Privacy/Termini	Iubenda	iubenda.com
Fatturazione	Fatture in Cloud	fattureincloud.it
Fatturazione (economico)	Aruba	aruba.it
Backend/DB	Firebase (Google)	firebase.google.com
Pagamenti carta	Stripe	stripe.com/it
Pagamenti IT	Satispay Business	business.satispay.com
Email transazionali	SendGrid o Resend	sendgrid.com / resend.com
SMS transazionali	Twilio o Skebby	twilio.com / skebby.it
Push notifications	Firebase Cloud Messaging	incluso in Firebase
Stock photos free	Pexels	pexels.com
CI/CD auto-deploy	GitHub Actions	github.com
Image hosting	Cloudinary	cloudinary.com
Monitoring/Errori	Sentry	sentry.io
Analytics privacy-friendly	Plausible o Umami	plausible.io / umami.is
Stock photos premium	Adobe Stock	stock.adobe.com

13. Contatti utili (Italia)

- Garante Privacy: [gpdp.it](https://www.gpdp.it) (modulo data breach + reclami).
- AgID (Agenzia per l'Italia Digitale): [agid.gov.it](https://www.agid.gov.it) (linee guida tecniche).
- Agenzia delle Entrate: [agenziaentrate.gov.it](https://www.agenziaentrate.gov.it) (corrispettivi, fatture).
- INPS / INAIL: [inps.it](https://www.inps.it) / [inail.it](https://www.inail.it) (per dipendenti).
- Camera di Commercio Napoli: [na.camcom.it](https://www.na.camcom.it) (visure, registrazione marchi).
- Confcommercio / Confesercenti: associazioni di categoria con servizi assistenza.

⚠ Questo documento è un RIFERIMENTO PRATICO. Non sostituisce consulenza legale o fiscale specifica. Rivedere ogni 12 mesi o ad ogni cambio normativo rilevante. Per il rilascio in produzione validare ogni voce con un avvocato (privacy/consumatori) e con un commercialista (fiscale).